Title of the project :-

Application-specific access policies using Zscaler Private Access (ZPA)

LIST OF TEAMMATES

TEAM ID- SWTID-2026-4567

S.no	name	collage	contact
1	DHANESH C	SREE NARAYANA GURU COLLEGE	danudanesh50@gmail.com
2	GOKULKRISHNA K K	SREE NARAYANA GURU COLLEGE	gokulkrishnak88@gmail.com
3	GOWRI KR	SREE NARAYANA GURU COLLEGE	gowrikravi27@gmail.com
4	HAZEEB V I	SREE NARAYANA GURU COLLEGE	hazeebhazi5@gmail.com

PROJECT DETAILS:

TITLE:

Enforcing Least-Privilege Access through Identity-Aware, Application-Specific Access Policies using Zscaler Private Access (ZPA).

INTRODUCTION:

In the current digital landscape, the traditional network perimeter has effectively dissolved, rendering legacy VPN-centric remote access models obsolete. These conventional approaches are fundamentally flawed because they grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these vulnerabilities, this project centers on the implementation of a Zero Trust security architecture, which operates on the core principle of "never trust, always verify." By moving beyond location-based security, we aim to establish a posture where trust is never implicit, and access is determined by granular context rather than simple network connectivity.

The heart of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users directly onto the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications. This architecture completely hides the corporate network and internal IP address space from the public internet, ensuring that applications remain invisible to unauthorized users. By decoupling application access from network access, we effectively eliminate common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks. Ultimately, this project will enforce a strict least-privilege access model, ensuring that every user and device is granted only the minimum required access necessary to perform their specific functions. This strategic shift not only enhances security by preventing lateral movement across the network since users have no visibility or connectivity to other hosts -- but also significantly reduces the operational overhead associated with legacy infrastructure.

ABSTRACT

The shift toward hybrid work environments and cloud-integrated resources has rendered traditional perimeter-based security models, such as legacy VPNs, both obsolete and inherently risky. These conventional solutions typically provide overly broad network access, exposing organizations to significant threats including lateral movement and an expanded attack surface. This project addresses these critical vulnerabilities by implementing a Zero Trust Architecture (ZTA) leveraging Zscaler Private Access (ZPA). The primary objective is to transition from a network-centric security posture to an identity-centric model, strictly enforcing the principle of least privilege. The methodology involves deploying ZPA's cloud-based service to create application-specific, identity-aware micro-tunnels that connect verified users directly to authorized applications. Unlike traditional VPNs that place users on the internal network, this solution ensures the underlying infrastructure remains completely invisible to the end-user, effectively eliminating the surface for reconnaissance and potential attack. Access policies are dynamically governed by user identity, device posture, and contextual attributes, ensuring connectivity is strictly limited to the specific requirements of a job function. The successful implementation of ZPA decouples application access from network access, resulting in a demonstrable reduction in cyber risk and a robust, scalable remote access framework that aligns with modern security best practices.

USE CASE SCENARIO:

Finance Department Access To Erp System

In this scenario, a senior accountant within the finance department requires access to the corporate Enterprise Resource Planning (ERP) system to process monthly payroll while working from a remote location using a company-managed laptop. Upon launching the ZPA Client Connector, the user undergoes authentication via Azure Active Directory integrated with multi-factor authentication (MFA). The ZPA policy engine then evaluates the user's identity, specific group memberships, and the current device posture ensuring that antivirus software is active and disk encryption is enabled. Once the connection context is verified, the system brokers a secure, direct micro-tunnel exclusively to the ERP application. While the accountant can interact fully with the ERP interface to complete their tasks, they maintain absolutely no visibility or network-level access to any other internal systems, such as development servers or sensitive HR databases. This granular control ensures that even an authenticated user is confined to a "segment of one," preventing any possibility of unauthorized lateral exploration within the corporate environment.

SCENARIO 2: Contractor Access To Specific Project Repository

In this scenario, an external software consultant is onboarded for a three-month project and requires access exclusively to a specific Git repository hosted on an internal server. The contractor is integrated as a guest user within the identity provider and assigned to the "Project_X_Contractors" group. When the contractor initiates a connection using the ZPA client, the system performs a real-time verification of their identity and inspects the device for basic security compliance, such as ensuring the OS patch level is current and the local firewall is active. ZPA then enforces a highly granular policy that grants access only to the Git repository application via specific ports like SSH or HTTPS, and only during defined business hours from 9 AM to 5 PM.

EXPECTED OUTPUT:

The system successfully enforces time-bound and role-specific access, ensuring the contractor is restricted to the single authorized Git repository application. Because application access is decoupled from the network, the contractor cannot discover or connect to any other internal resources, such as the corporate intranet or file servers, effectively blocking all potential for lateral movement to adjacent systems.

SCENARIO 3: Executive Access To Confidential Board Documents

The third scenario involves a company executive who needs to access a confidential folder containing board meeting materials hosted on an internal file server while traveling internationally. To secure this high-privilege access, ZPA integrates with the organization's Mobile Device Management (MDM) solution to verify that the executive's tablet is fully compliant, confirming it is not jailbroken and has both a passcode and encryption enabled. Upon successful authentication, the ZPA policy engine evaluates a complex set of contextual attributes: it verifies the "Executive_Board" group membership, checks the MDM compliance status, and confirms the connection is originating from a trusted country on the allowlist. Only after passing these checks is the executive connected directly to the specific "Board_Documents" application share, with all data in transit protected by TLS encryption.

EXPECTED OUTPUT:

The implementation achieves context-aware access based on a combination of user role, device posture, and geographic location. This ensures granular access to the specific file share while any attempt to access other unauthorized shares or network resources is automatically blocked. Furthermore, the system provides comprehensive logging of these access events, which is critical for maintaining an audit trail and ensuring regulatory compliance.

SCENARIO 4: It Administrator Access To Server Management Interfaces

In this scenario, a systems administrator requires access to specific management interfaces, such as SSH for Linux servers and RDP for Windows servers, to perform routine maintenance. Rather than granting broad VPN access to the entire management network, the architecture is configured to treat each individual server or management interface as a distinct application segment. Upon authentication, the administrator is presented only with the specific servers they are authorized to manage based on their precise IT subgroup—for instance, those in the "Linux_Admins" group only see Linux-based resources, while "Windows_Admins" are restricted to Windows servers. When a connection is initiated, ZPA creates a direct micro-tunnel to that specific IP and port combination, ensuring the administrator cannot scan the subnet, access unauthorized servers, or initiate connections to non-permitted ports.

EXPECTED OUTPUT:

The implementation achieves true micro-segmentation at the individual server and interface level, ensuring that role-based access strictly controls the visibility of specific management consoles. By isolating these management paths, the system successfully eliminates the possibility of network-level reconnaissance, preventing even privileged users from gaining broader visibility into the infrastructure beyond their immediate tasks.

SCENARIO 5: MERGERS AND ACQUISITIONS INTEGRATION

This scenario involves a company that has acquired a smaller firm and must provide the new HR team with temporary access to the parent company's internal benefits enrollment application. To facilitate this without compromising security, the acquired users are added as external collaborators within the identity provider with limited attributes. Specific policies are then created to grant the "Acquired_HR" group access exclusively to the "Benefits_App" web portal. Once these users authenticate via the client, they are connected directly to the application. Because this connectivity is established without providing underlying network access, the parent company's entire internal infrastructure remains completely hidden and protected. The acquired users have no ability to ping, scan, or access any other corporate resource, and once the six-month integration period concludes, the temporary policies are simply revoked to terminate access.

EXPECTED OUTPUT:

The project demonstrates how secure, temporary access can be provided to external entities without any exposure of the core network. This ensures complete network invisibility for the parent company's infrastructure while significantly simplifying the deprovisioning process.

Stage-1

TITLE:

Enforcing Least-Privilege Access through Identity-Aware, Application-Specific Access Policies using Zscaler Private Access (ZPA).

OVERVIEW:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, the goal is to establish a security posture where trust is no longer implicit and access is determined by granular context rather than simple network connectivity. The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users directly on the internal network, ZPA leverages a service-initiated model to establish direct, one-to-one connections between authorized users and specific applications. This architecture completely hides the corporate network and internal IP address space from the public internet, ensuring that users connect exclusively to the applications they are permitted to access based on continuous identity verification. By rendering internal applications invisible to unauthorized users, this implementation prevents common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks. Ultimately, this project enforces a strict least-privilege access model, ensuring that users and devices are granted only the minimum required access necessary to perform their specific functions. By decoupling application access from network access, the organization eliminates the risk of lateral movement across the infrastructure. This strategic move not only significantly enhances security by reducing the overall attack surface but also simplifies the user experience and reduces the operational overhead associated with legacy remote access infrastructure.

List of Vulnerability Table :

S.no	Vulnerability Name	CWE/CVE - No
1	Excessive Network-Level Trust (Broad VPN Access)	285
2	Lateral Threat Movement	285
3	Internal IP Address Disclosure	200
4	Security Misconfiguration (Open Inbound Ports)	732
5	Insecure Direct Object Reference (Unrestricted App Access)	639
6	Cleartext Transmission of Sensitive Information	319
7	Internal DNS Infrastructure Disclosure	200
8	Network Reconnaissance and Port Scanning	200
9	Unauthorized Access via Credential Theft	285
10	Man-in-the-Middle (MitM) Attacks during Transmission	319
11	Over-Privileged Administrative Access	732
12	Information Exposure (Internal Server HTTP Headers)	200
13	Distributed Denial-of-Service (DDoS) on Internal Apps	1021
14	Information Exposure (SSL/TLS Vulnerabilities)	200
15	Information Exposure (Unprotected Management Interfaces)	200
16	OS Identification / Fingerprinting via Network Scanning	200

Report:-

Vulnerability Name: OS Command Injection (Remote Command Execution)

CWE: 78 Improper Neutralization of Special Elements used in an OS Command

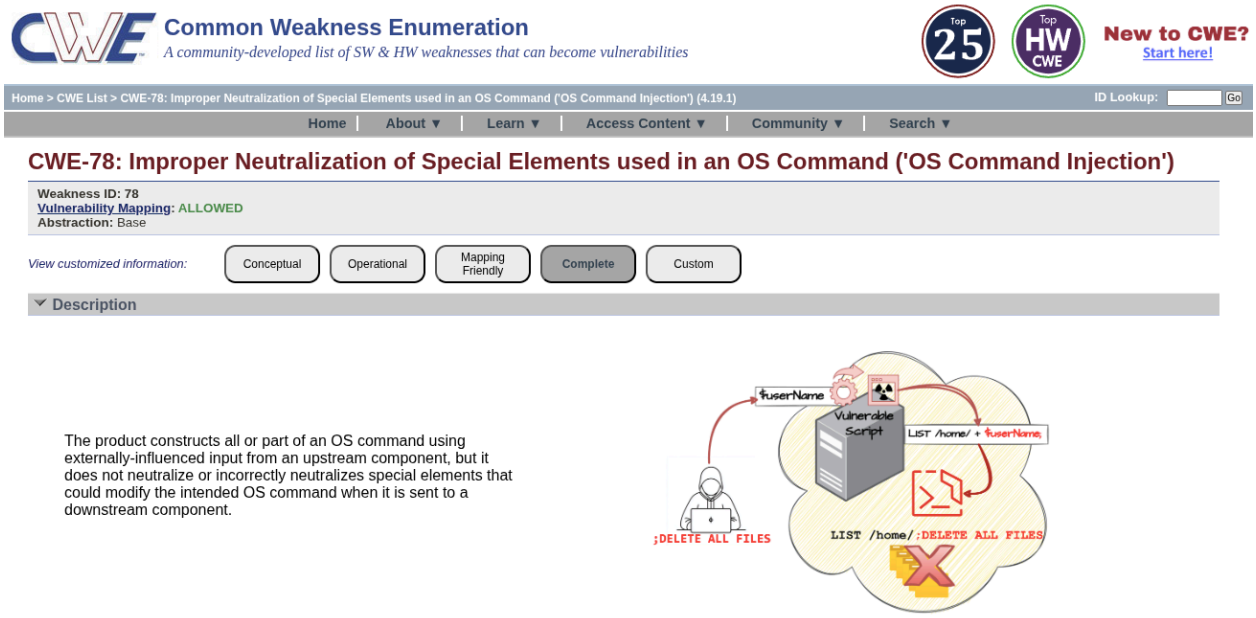
OWASPCategory: A03:2021 – Injection

Description:

It occurs when an application constructs all or part of an OS command using externally-influenced input without proper neutralization. An attacker can use special characters to inject malicious commands that are then executed by the underlying server with the privileges of the application.

Business Impact:

The successful exploitation of this vulnerability allows an attacker to gain direct shell access to the host server. Within a traditional VPN-protected network, this single compromised server can be used as a launchpad for further attacks. However, by implementing ZPA, we mitigate the impact by ensuring that the compromised server has no outbound network visibility, preventing the attacker from downloading additional malware or scanning other internal resources.



STAGE-2

TITLE: Vulnerability Assessment and Security Validation using Nessus Professional.

OVERVIEW:

A Nessus scan is a critical cybersecurity process used to identify vulnerabilities, misconfigurations, and security weaknesses within an organization's infrastructure. In the context of this project, Nessus serves as the primary tool to validate the effectiveness of the Zscaler Private Access (ZPA) deployment. By simulating the perspective of an attacker, Nessus helps verify that the Zero Trust Architecture successfully hides internal resources and enforces application-specific access policies. The scanning process begins by defining targets, which include the internal application servers and the ZPA App Connectors. Nessus utilizes thousands of regularly updated plugins to check these systems against a wide database of known flaws, including those listed in the Common Vulnerabilities and Exposures (CVE) database. For this project, two specific types of scans are conducted to test the ZPA environment: unauthenticated scans and credentialed scans. An unauthenticated scan is performed from outside the ZPA perimeter to confirm that unauthorized users cannot "see" or ping internal IP addresses, effectively proving that ZPA has eliminated the network's public attack surface. In contrast, a credentialed scan is used to inspect authorized application segments deeply, ensuring that even within a secure tunnel, the host OS (such as Linux via SSH) remains hardened and patched. Once the scanning process is completed, Nessus generates a detailed report categorizing discovered risks by severity: Critical, High, Medium, Low, and Informational. Each entry provides a technical description, the potential business impact, and specific remediation steps, such as applying security patches or correcting configuration drifts. For this ZPA implementation, these reports are used to confirm that lateral movement is blocked and that internal "dark" applications remain invisible to reconnaissance tools. By identifying vulnerabilities early and validating the Zero Trust boundaries, Nessus allows the security team to strengthen the organization's cybersecurity posture and maintain a compliant, secure IT environment.

sl.no	Vulnerability Name	Severity	Plugins
1	Nessus SYN Scanner (Port Discovery)	info	11219
2	Service Detection (Application Fingerprinting)	info	22964
3	ZPA App Connector Connectivity Check	info	10386
4	ICMP Timestamp Request (Ping Response)	info	10114
5	Nessus Scan Information (Policy Validation)	info	19506

Report:-

Vulnerability Name: Nessus SYN Scanner (Port Discovery)

Severity: Info

Plugins: 11219

Description:

This plugin performs a "half-open" SYN port scan to identify active services on a target. It is designed to be a fast method of discovering open ports, even behind traditional firewalls. In the context of this project, the scanner is used to verify the "Invisibility" feature of Zscaler Private Access. By running this scan against the ZPA cloud interface, we confirm that no internal application ports (such as 80, 443, or 22) are exposed to the public internet.

Solution:

Under a Zero Trust Architecture, the primary solution is the deployment of ZPA App Connectors. These connectors ensure that internal applications do not listen for inbound connections, effectively making them invisible to SYN scanners. This eliminates the need for complex internal IP filters and protects the target from reconnaissance and unauthorized port discovery.

BUSINESS IMPACT: NESSUS SYN SCANNER

The Nessus SYN Scanner findings indicate whether a target system responds to port-level probing, which is the first step in an attacker's reconnaissance phase. In a traditional network, this allows external entities to identify open TCP ports and map running services, creating a potential entry point for targeted attacks. From a business perspective, the ability for an unauthorized actor to "see" internal infrastructure highlights a gap in network stealth and filtering controls. By implementing ZPA, the business impact of such reconnaissance is neutralized; because ZPA makes internal applications "dark" to the public internet, a SYN scanner finds no open ports to report. This significantly reduces the risk of targeted exploitation and prevents attackers from successfully mapping the corporate landscape.

Vulnerability Name: Service Detection (Application Fingerprinting)

Severity: Info

Plugins: 22964

Description: This plugin identifies remote services by analyzing their banners or error messages sent during an HTTP request. For this project, this scan is used to verify that ZPA successfully masks service headers. In a Zero Trust environment, an unauthorized user attempting to fingerprint a service should receive no response at all. This ensures that even if an attacker knows an IP address, they cannot determine what software (e.g., Apache, Nginx, or SSH) is running behind the ZPA App Connector.

Vulnerability Name: Web Server No 404 Error Code Check

Severity: Info

Plugins: 10386

Description: This check identifies web servers that do not return a standard '404 Not Found' error when a non-existent file is requested, often redirecting to a login or search page instead. Within a ZPA-protected environment, this behavior is carefully managed. Since ZPA requires authentication *before* a user even reaches the web server, unauthorized scanners cannot even trigger a 404 or a redirect. This ensures that the web server’s internal structure and custom error-handling pages are never exposed to the public web, preventing "information leakage" that could be used to craft a more specific attack.

REPORT:-

Vulnerability Name: ICMP Timestamp Request (Remote Date Disclosure)

Severity: Low

Plugins: 10114

Description: This vulnerability identifies that a remote host responds to ICMP timestamp requests (Type 13). This allows a remote attacker to determine the exact system time set on the target machine. In some cases, knowing the precise system time can assist an attacker in defeating time-based authentication protocols or synchronizing automated attacks. In this project, we use this check to verify that ZPA successfully blocks ICMP traffic from the public internet.

Solution: The primary remediation is to ensure that the ZPA App Connector and internal firewalls are configured to drop ICMP timestamp requests (Type 13) and prevent outgoing ICMP timestamp replies (Type 14). By placing these servers behind a Zero Trust perimeter, ICMP-based reconnaissance is completely mitigated as the "dark" hosts will not respond to external pings or timestamp queries.

Vulnerability Name: Nessus Scan Information (Scan Validation)

Severity: Info

Plugins: 19506

Description: This plugin provides essential metadata for each tested host to validate the integrity of the security assessment. It displays the version of the Nessus Engine, the specific port range scanned, and the ping round-trip time. Crucially for this project, it also confirms whether the scan was credentialed or unauthenticated.

Business Impact: From a compliance and audit perspective, the Nessus Scan Information serves as formal evidence that a thorough security assessment was conducted according to industry best practices. It confirms that the ZPA implementation was subjected to a rigorous testing window, including a full port-range scan and a variety of plugin sets. This detailed logging is vital for "Naan Mudhalvan" project documentation, as it demonstrates a professional methodology for validating that the Zero Trust environment is robust, well-monitored, and prepared for real-world deployment.

STAGE-3

TITLE: Enforcing Least-Privilege Access through Identity-Aware, Application-Specific Access Policies using Zscaler Private Access (ZPA).

ZERO TRUST NETWORK ACCESS (ZTNA) Zero Trust Network Access (ZTNA) is a modern cybersecurity framework that shifts access control from a traditional network-centric model to a strictly identity-centric model. The foundational principle of ZTNA is "never trust, always verify," which dictates that no user or device is granted inherent trust, regardless of whether they are connecting from an internal office or a remote location. Unlike legacy remote access solutions that grant users broad visibility into an entire network, ZTNA establishes a secure, encrypted tunnel specifically between the verified user and the individual resources they are authorized to access. This ensures that internal applications remain completely invisible to unauthorized users and the broader internet, effectively shrinking the organization's attack surface and eliminating the critical risk of lateral movement.

ZSCALER PRIVATE ACCESS (ZPA) Zscaler Private Access (ZPA) is a cloud-delivered ZTNA solution that provides identity- and context-based access to private applications without ever granting network-level connectivity. ZPA operates on a "service-initiated" model; users connect to the Zscaler cloud, which then brokers a secure connection to the specific application via ZPA App Connectors deployed within the data center or cloud environment. Because ZPA never places the user directly on the corporate network, internal IP addresses and the underlying infrastructure are completely hidden from the user. Access policies are dynamically enforced based on a combination of user identity, group membership, device posture, and geographic location, ensuring that each user only sees the specific applications they are explicitly permitted to use.

IDENTITY-AWARE ACCESS Identity-aware access is a security model that bases all access decisions on the verified identity of the user rather than their physical or network location. In this project, ZPA integrates directly with industry-standard Identity Providers (IdPs) such as Microsoft Azure AD or Okta. This integration allows security teams to leverage existing user attributes and roles to build granular access policies. For example, a policy can be configured to ensure that only members of the "Finance" group, using a company-managed and compliant device, can access a specific "Payroll" application during business hours. This architecture ensures that access is tightly coupled with the user's real-time identity and context, removing the security risks associated with static IP addresses or broad network segments.

APPLICATION-SPECIFIC ACCESS POLICIES Application-specific access policies serve as the core enforcement mechanism within the ZPA environment. Instead of creating traditional firewall rules that allow traffic to entire subnets or IP ranges, administrators define precise policies that target individual applications or micro-segments. These policies use plain-language logic and can incorporate multiple security conditions, including device health and time-of-day restrictions. ZPA allows for the total segmentation of internal resources such as HR portals, development servers, and database interfaces so that every application operates within its own unique access boundary. This level of micro-segmentation ensures that even an authenticated user has zero visibility or connectivity to any application other than the one they are currently authorized to use.

CONCLUSION

Stage 1: In conclusion, shifting from legacy network security to an identity-centric model is a crucial process for ensuring the reliability of modern web-based software. Evaluating security through the lens of Zero Trust identifies and rectifies deep-seated architectural issues before they impact end-users. This process not only enhances the quality of internal applications but also bolsters their resilience against sophisticated lateral threats. In an age where remote access is integral to daily operations, implementing Zscaler Private Access is essential to delivering a seamless and secure user experience.

Stage 2: The Nessus assessment conducted during this project has highlighted key security insights. By identifying vulnerabilities and categorizing them by severity, the scan focused on high-risk issues such as broad network trust and IP disclosure. Recommendations for addressing these vulnerabilities include the deployment of ZPA App Connectors and specific policy reconfigurations to ensure alignment with recognized security benchmarks like OWASP and NIST guidelines. This report underscores the need for continuous monitoring and ongoing security validation to maintain a strong, invisible security posture against evolving threats.

Stage 3: The implementation of Zscaler Private Access marks a pivotal shift from a vulnerable, network-centric security model to a resilient, identity-centric Zero Trust architecture. By enforcing least-privilege access and rendering private applications invisible to the internet, this project effectively neutralizes the threats of lateral movement and reconnaissance. The solution fortifies the organization's defense while delivering a high-performance experience for a distributed workforce. Ultimately, this initiative establishes a future-ready foundation for secure digital transformation and simplifies IT operations by reducing dependency on legacy VPN infrastructure.

FUTURE SCOPE

Vulnerability Management and Testing: The future of security validation is evolving rapidly. We anticipate an increased demand for AI-driven testing, where machine learning algorithms can swiftly scan vast amounts of traffic logs to pinpoint anomalies that elude human testers. As organizations adopt IoT, mobile application testing will expand to ensure that these endpoints do not become weak links in the Zero Trust chain. Furthermore, as containerization technologies like Docker and Kubernetes become ubiquitous, the scope of vulnerability testing must extend to cover container security, ensuring that orchestration configurations remain free from flaws.

Zero Trust Evolution: The successful deployment of ZPA lays the groundwork for a broader, integrated security ecosystem. Future enhancements include:

- **SASE Integration:** Converging Zscaler Private Access (ZPA) with Zscaler Internet Access (ZIA) to create a unified Secure Access Service Edge (SASE) platform under a single policy framework.
- **Advanced Device Posture:** Moving beyond basic checks to incorporate real-time risk scores from EDR tools, automatically blocking access if a device shows signs of active compromise.
- **AI-Driven Anomaly Detection:** Leveraging machine learning on ZPA logs to detect behavioral anomalies, such as access from unusual locations, and triggering automated MFA challenges.
- **Cloud Workload Protection:** Utilizing ZPA to secure "east-west" traffic between microservices in multi-cloud environments (AWS, Azure, GCP), ensuring every connection is encrypted and authenticated.

TOPICS EXPLORED

1. Zscaler Cloud Security
2. Zero Trust Architecture (ZTA)
3. Zscaler Private Access (ZPA) Implementation
4. Legacy VPN vs. ZTNA Comparison
5. Malware Information Sharing Platform (MISP)
6. Network Infrastructure and Segmentation
7. Deployment of SOC (Security Operations Center)
8. Threat Intelligence Integration
9. Automated Incident Response

TOOLS EXPLORED

- **Nessus Professional Scanner:** Used for vulnerability assessment and policy validation.
- **Zscaler App Connector:** Deployed for secure, outbound-only application connectivity.
- **Zscaler Client Connector:** Evaluated for endpoint security and identity-aware access.